

GUÍA METODOLÓGICA DETALLADA

Kit de Encuesta CIA Triad — Diagnóstico de Madurez en Ciberseguridad

Versión 2025 • Para Investigadores y Coordinadores

1. FUNDAMENTOS EPISTEMOLÓGICOS Y MARCO TEÓRICO

1.1. Base Conceptual

Esta encuesta se ancla epistemológicamente en el modelo CIA Triad como arquetipo consolidado de la teoría de seguridad de la información, complementado con las extensiones CIANA (Confidentiality, Integrity, Availability, Non-repudiation, Authenticity) reconocidas por el ENS español (RD 311/2022) y la ISO/IEC 27000 family.

Marcos normativos que fundamentan los ítems:

Marco	Aplicabilidad	Pilares CIA Cubiertos
NIST CSF 2.0 (2024)	Global / referencia	C + I + A
NIST SP 800-53 Rev. 5	Sector público / referencia	C + I + A + No repudio
ISO/IEC 27001:2022	Internacional / certificación	C + I + A
ENS (RD 311/2022)	España — AAPP y proveedores	C + I + A + Autenticidad + Trazabilidad
NIS2 / Anteproyecto LCGC	UE / sectores esenciales	A (principal) + C + I
DORA	UE / sector financiero	A (resiliencia operacional) + C + I
ISO/IEC 27701:2025	Internacional / privacidad	C
NIST PQC (FIPS 203/204/205)	Global / criptografía	C + I

1.2. Diseño del Instrumento

El instrumento de medición sigue la metodología **GQM (Goal-Question-Metric)**, ampliamente utilizada en investigación de calidad de software y adaptada al dominio de la ciberseguridad:

OBJETIVO (Goal): Medir la madurez operativa en las dimensiones CIA

↓

PREGUNTA (Question): ¿Qué controles implementa la organización?

↓

MÉTRICA (Metric): Indicadores cuantitativos y cualitativos de implementación

1.3. Modelo de Madurez Subyacente

El modelo de madurez utilizado combina elementos del **CMMI** (Capability Maturity Model Integration) y el **C2M2** (Cybersecurity Capability Maturity Model), adaptados a la escala Likert de 5 niveles:

Nivel	CMMI Equivalente	C2M2 Equivalente	Descripción Operativa
1	Initial	MIL0	Sin procesos definidos; heroísmo individual
2	Managed	MIL1	Procesos reactivos; documentación irregular
3	Defined	MIL2	Procesos estandarizados; implementación consistente
4	Quantitatively Managed	MIL3	Métricas formales; mejora basada en datos
5	Optimizing	MIL3+	Mejora continua; benchmarking externo; anticipación

2. DISEÑO MUESTRAL

2.1. Universo Poblacional

Población objetivo primaria: Responsables de ciberseguridad en organizaciones con sede o actividad relevante en España.

Perfiles de respondentes válidos (en orden de preferencia):

1. CISO (Chief Information Security Officer)
2. CIO / Director de Tecnología con responsabilidad en seguridad
3. CTO en organizaciones sin CISO
4. DPO (Data Protection Officer) — para preguntas de confidencialidad
5. Responsable de Sistemas / Director de TI con responsabilidad de seguridad
6. Responsable de Cumplimiento (Compliance Officer) con competencia en ciberseguridad
7. Responsable de Continuidad de Negocio / BCP Manager

Perfiles no válidos como respondentes únicos:

- Técnicos de helpdesk sin responsabilidad directiva
- Personal de negocio sin responsabilidad TI
- Consultores externos sin conocimiento del entorno operativo real de la organización

2.2. Segmentación de la Muestra

Para análisis comparativo estadísticamente significativo, se recomienda la siguiente estratificación:

Por tamaño organizacional:

- Microempresas (< 50 empleados): $n \geq 30$
- PYMEs (50-250): $n \geq 50$
- Medianas empresas (251-1.000): $n \geq 50$
- Grandes empresas y corporaciones (> 1.000): $n \geq 50$

Por sector (sectores prioritarios según criticidad NIS2):

- Banca y finanzas: $n \geq 30$
- Administración pública: $n \geq 30$
- Energía: $n \geq 20$
- Salud: $n \geq 20$
- Transporte: $n \geq 20$
- TIC y telecomunicaciones: $n \geq 20$
- Otros sectores: $n \geq 30$

Tamaño muestral mínimo recomendado: $n = 300$ (margen de error $\pm 5,6\%$ con NC 95%)

Tamaño muestral óptimo: $n = 500$ (margen de error $\pm 4,4\%$ con NC 95%)

2.3. Método de Muestreo

Se recomienda muestreo **estratificado no proporcional** con afijación óptima (Neyman) para garantizar representatividad en estratos pequeños (sectores de nicho o microempresas) manteniendo poder estadístico en el análisis comparativo.

3. ADMINISTRACIÓN DE LA ENCUESTA

3.1. Modalidades de Distribución

Modalidad	Ventajas	Limitaciones	Recomendación
CAWI (web, auto-administrada)	Escalable, bajo coste, anónima	Baja tasa de respuesta, sesgo de auto-selección	Principal
CATI (telefónica asistida)	Mayor tasa de respuesta, clarificación	Costosa, sesgo del entrevistador	Complementaria
CAPI (presencial asistida)	Máxima calidad de datos	Muy costosa, muestra limitada	Casos cualitativos
Panel online especializado	Muestra controlada y cualificada	Coste elevado, disponibilidad limitada	Recomendada para B2B

Plataformas recomendadas para implementación CAWI:

- Google Forms (opción económica, funcionalidades básicas)
- Microsoft Forms (integración corporativa)
- SurveyMonkey / Typeform (experiencia usuario superior)
- LimeSurvey (open source, máximo control de datos — recomendado por RGPD)
- Qualtrics (investigación académica avanzada)

3.2. Cronograma Tipo de Campo

Semana 1: Diseño final y prueba piloto (n=10-15)
Semana 2: Ajustes basados en piloto + envío oleada 1
Semanas 3-4: Ventana de respuesta + recordatorios (días 7 y 14)
Semana 5: Cierre de campo + verificación de calidad
Semanas 6-7: Limpieza, codificación y análisis
Semana 8: Redacción de informe y reporte ejecutivo

3.3. Incentivos y Tasas de Respuesta Esperadas

Estrategia de incentivo	Tasa de respuesta esperada
Sin incentivo (fría)	5-10%
Acceso al informe agregado de resultados	15-25%
Benchmarking personalizado (comparativa sector)	25-35%
Webinar exclusivo de resultados	30-40%
Combinación: informe + benchmarking	35-45%

4. CODIFICACIÓN Y PUNTUACIÓN

4.1. Sistema de Puntuación por Bloque

Preguntas de Escala Likert (madurez 1-5)

Las preguntas P1.16, P2.14, P3.16 y P8.1 se puntúan directamente de 1 a 5.

Preguntas de Opción Única con Peso de Madurez

Cada opción de respuesta tiene asignado un peso de madurez implícito (1-5). El coordinador debe usar la siguiente tabla de conversión:

Ejemplo — P1.1 (Cobertura MFA):

Respuesta	Puntuación
Menos del 25%	1
Entre 25% y 50%	2
Entre 51% y 75%	3
Entre 76% y 90%	4
Más del 90%	4,5
100%, incluidas cuentas privilegiadas	5

Ejemplo — P3.3 (RTO):

Respuesta	Puntuación
Menos de 15 minutos	5
Entre 15 min y 1 hora	4

Entre 1 y 4 horas	3
Entre 4 y 24 horas	2
Más de 24 horas	1
Sin RTO definido	0 (alerta crítica)

4.2. Cálculo del Índice Global de Madurez (IGM)

El **Índice Global de Madurez CIA (IGM-CIA)** se calcula como la media ponderada de los tres pilares:

$$\text{IGM-CIA} = (w_C \times P_C) + (w_I \times P_I) + (w_A \times P_A)$$

Donde:

- P_C = Puntuación media de Confidencialidad (promedio de todas las preguntas del Bloque 1)
- P_I = Puntuación media de Integridad (promedio de todas las preguntas del Bloque 2)
- P_A = Puntuación media de Disponibilidad (promedio de todas las preguntas del Bloque 3)

Ponderaciones por defecto (ajustables por sector):

Sector	w_C	w_I	w_A
Banca / Finanzas	0,35	0,30	0,35
Salud	0,40	0,35	0,25
Energía / Utilities	0,25	0,30	0,45
Administración Pública	0,35	0,35	0,30
TIC / Telecomunicaciones	0,30	0,30	0,40
Industria / Manufactura	0,30	0,35	0,35
Genérico	0,33	0,33	0,34

Interpretación del IGM-CIA:

Rango IGM	Nivel	Interpretación	Acción Recomendada
1,0 - 1,9	Crítico	Exposición severa, múltiples vectores de ataque	Plan de emergencia inmediato
2,0 - 2,9	Deficiente	Controles básicos, brechas sistémicas	Plan de mejora prioritario (6 meses)
3,0 - 3,9	En desarrollo	Marco establecido, ejecución irregular	Hoja de ruta de madurez (12 meses)
4,0 - 4,4	Competente	Controles sólidos, mejora continua	Optimización y benchmarking
4,5 - 5,0	Líder	Madurez avanzada, referente sectorial	Participación en compartición de intel

4.3. Indicadores Automáticos de Alerta

Las siguientes respuestas deben generar una **alerta roja automática** independientemente del IGM:

Pregunta	Respuesta de Alerta	Riesgo Asociado
P1.5	"Cuentas de administrador compartidas sin rotación"	Compromiso de privilegios inminente
P1.8	"3DES u otros algoritmos legacy"	Vulnerabilidad criptográfica crítica
P2.3	"Más de 90 días de parcheo"	Exposición CVE crítica activa
P3.5	"No recordamos última verificación"	Riesgo de BCP inoperante
P3.7	"Nos enteramos de los incidentes por usuarios"	Sin capacidad de detección
P3.1	"No existe BCP formal"	Riesgo de continuidad crítico
P5.3	"No somos conscientes de los requisitos"	Riesgo regulatorio / sanción

5. ANÁLISIS ESTADÍSTICO

5.1. Estadísticos Descriptivos por Variable

Para cada ítem de escala, calcular:

- Media aritmética (μ)
- Desviación estándar (σ)
- Mediana y moda
- Distribución de frecuencias por categoría
- Intervalos de confianza al 95%

5.2. Análisis Comparativo

Tests estadísticos recomendados:

Comparación	Test Recomendado	Condición
IGM por sector ($k > 2$ grupos)	ANOVA de un factor + Tukey HSD	Distribución normal
IGM por tamaño	Kruskal-Wallis	Distribución no normal
Correlación entre pilares	Correlación de Pearson / Spearman	Según distribución
Asociación variables categóricas	Chi-cuadrado (χ^2)	n esperado > 5 por celda
Madurez vs. número de incidentes	Regresión logística binaria	Variable dependiente binaria

5.3. Análisis de Fiabilidad del Instrumento

Calcular el **Alfa de Cronbach** para cada bloque temático:

- Valor aceptable: $\alpha \geq 0,70$
- Valor bueno: $\alpha \geq 0,80$
- Valor excelente: $\alpha \geq 0,90$

Para ítems no escalares (categoriales), utilizar el **KR-20** (Kuder-Richardson para ítems dicotómicos) o el **Alfa de Cronbach ordinal** (policórico).

5.4. Análisis de Componentes Principales (ACP)

Se recomienda ACP para identificar dimensiones latentes no explícitas en el modelo CIA, potencialmente revelando agrupaciones de controles que superan los tres pilares tradicionales.

6. CONSIDERACIONES ÉTICAS Y RGPD

6.1. Principios Aplicables

- Minimización de datos: Solo recoger información necesaria para los objetivos de investigación
- Seudonimización: Las respuestas se vincularán a un código alfanumérico, no a identificadores directos
- Limitación de conservación: Datos brutos eliminados a los 24 meses tras el cierre del estudio
- Base legal: Interés legítimo (investigación académica/institucional) o consentimiento explícito

6.2. Hoja de Información al Participante

Debe incluirse antes del instrumento:

- Identificación del responsable del tratamiento
- Finalidad del estudio
- Receptores de los datos (solo en forma agregada y anonimizada)
- Ejercicio de derechos RGPD (acceso, rectificación, supresión)
- Contacto del DPO

6.3. Conflictos de Interés

Se recomienda declaración explícita de ausencia de conflictos de interés del equipo investigador y del patrocinador (si lo hubiere), garantizando la independencia del análisis.

7. LIMITACIONES METODOLÓGICAS

Limitación	Descripción	Mitigación
Sesgo de deseabilidad social	Los respondentes tienden a sobrevalorar sus controles	Preguntas de verificación cruzada; garantía de anonimato
Sesgo de auto-selección	Las organizaciones más maduras participan más	Incentivos diferenciados; colaboración con asociaciones sectoriales
Varianza del método común	Al ser auto-reporte, puede inflarse la correlación entre variables	Separar temporalmente ítems correlacionados; validación externa
Variación del respondente	Diferentes roles responden diferente al mismo estado real	Definir perfil único por organización; instrucciones claras
Obsolescencia rápida	Las métricas de ciberseguridad cambian a gran velocidad	Revisión anual del instrumento; control de versiones

Guía Metodológica CIA Triad Survey Kit v2025 · Basada en: GQM methodology, CMMI, C2M2, ISO/IEC 27001:2022, NIST CSF 2.0, ENS RD 311/2022